

MAPEO DETALLADO: PREGUNTAS GQM → REQUISITOS NORMATIVOS

Trazabilidad Indicadores ↔ Regulaciones España/EU

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: España | Indicadores Ciberseguridad-IA

Normativa Base: Plan Nacional Ciberseguridad, NIS2, EU AI Act, ISO 27001, GDPR, DORA

INTRODUCCIÓN: MATRIZ DE ALINEACIÓN NORMATIVA

Este documento proporciona mapeo **línea-por-línea** de cada pregunta GQM de los 9 indicadores contra:

1. Marcos Regulatorios Nacionales/Internacionales
2. Requisitos Técnicos Específicos
3. Plazos de Cumplimiento
4. Organismos de Supervisión/Validación

Normativas Incluidas:

-  Plan Nacional de Ciberseguridad España (2023)
-  Directiva NIS2 (Transposición 2025)
-  EU AI Act (Effective 2025-2026)
-  ISO 27001:2022
-  GDPR (Data Protection)
-  DORA (Digital Operational Resilience - Finance)
-  COBIT 2019 (Governance)

SECCIÓN 1: INDICADOR 1 - AI-THREAT DETECTION

Pregunta GQM 1.1: Coverage % Infraestructura Crítica

Aspecto	Detalle
Pregunta	¿Qué % infraestructura crítica tiene sistemas detección IA-specific deployed?
Métrica	M1.1: AI-Detection Coverage %
Normativa 1: Plan Nacional Ciberseguridad 2023	Línea 4.3: "Entidades críticas deberán implementar capacidades detección amenazas avanzadas con latencia <24h"
Normativa 2: NIS2 Directiva	Artículo 17: "Operadores servicios esenciales deben implementar sistemas detección incidentes para infraestructura crítica; supervisión CNCS"
Normativa 3: ISO 27001:2022	Control A.16.1.5: "Monitoring and recording of activities; incident detection systems required"
Normativa 4: EU AI Act	Artículo 37: "AI-generated threat systems subject to risk assessment; documentation required"
Requisito Técnico	Logging centralizado; correlación eventos; automated alerts; <30min detection latency preferred
Plazo de Cumplimiento	NIS2: Agosto 2026 (Essential Entities) / October 2024 (Important Entities)
Organismo Supervisión	CNCS (Centro Nacional Ciberseguridad España) + INCIBE (auditoría)
Puntuación Mínima Compliance	80% cobertura (Nivel 3 en GQM)
Auditoría/Validación	CNCS assessments; INCIBE certifications; external pen testing

Pregunta GQM 1.2: MTTD Promedio (Días)

Aspecto	Detalle
Pregunta	¿Cuál es Mean Time to Detect (MTTD) para ataques IA vs convencionales?
Métrica	M1.2: MTTD IA-Threats (días)
Normativa 1: Plan Nacional	Línea 4.3.2: "Tiempo máximo detección: 181 días – reducir a <24 horas en 2026" (baseline 2025: 181d)
Normativa 2: NIS2	Artículo 18: "Reporting incidentes de relevancia: within 72 hours of discovery; Competent Authority notification"
Normativa 3: GDPR	Artículo 33: "Personal data breach notification: 72 hours to authority if risk to rights/freedoms"
Normativa 4: ISO 27001	Clause 8.3.1: "Detection and response: must have mechanisms to identify and contain incidents"
Requisito Técnico	SIEM setup; ML-based correlation; threat intelligence integration; automated escalation
Plazo Cumplimiento	Inmediato (GDPR 72h non-negotiable; NIS2 immediate 2026)
Organismo Supervisión	AEPD (Autoridad Protección Datos); CNCS; Autoridades Competentes autonómicas
Puntuación Mínima Compliance	<30 días MTTD (Nivel 3); aspiración <24h (Nivel 5)
KPI Medible	$\Sigma(\text{Detection_date} - \text{Incident_actual_date}) / n_incidents$

Pregunta GQM 1.3: False Positive Rate %

Aspecto	Detalle
Pregunta	¿Cuál es tasa false positives sistemas detección IA?
Métrica	M1.3: False Positive Rate %
Normativa 1: ISO 27001:2022	A.16.1.1: "Sensors and tools for detection shall be tuned to minimize false alerts; documentation required"
Normativa 2: COBIT 2019	DSS01.07: "Alert tuning: FP rate should be <10% para mantener analyst efficiency"
Normativa 3: Plan Nacional	Línea 5.2: "Operacionalidad SOC: FP rate <15% es baseline acceptable; <5% is best practice"
Requisito Técnico	Machine learning model tuning; baseline behavior analysis; contextual alerting
Plazo Cumplimiento	Baseline establecido Q1 2026; mejora continua 2026-2027
Organismo Supervisión	INCIBE (auditoría interna); CNCS (benchmarking)
Puntuación Mínima Compliance	<30% FP rate (Nivel 2); <15% (Nivel 3); <5% (Nivel 5)
Impact si No Cumple	Analyst alert fatigue → detection evasion → regulatory breach

Pregunta GQM 1.4: Model Accuracy vs Adversarial

Aspecto	Detalle
Pregunta	¿Accuracy modelo ML ante adversarial attacks (robustness)?
Métrica	M1.4: Model Accuracy vs Adversarial %
Normativa 1: EU AI Act	Artículo 15: "Model robustness: AI systems in security must have adversarial testing documentation; conformity assessment required"
Normativa 2: NIST AI RMF	Govern function: "Model governance includes adversarial testing; risk mitigation documented"
Normativa 3: ISO/IEC 42001 (AI Management)	Section 7.3: "AI system testing: adversarial robustness testing is mandatory for security-critical systems"
Requisito Técnico	Red team testing; adversarial sample generation; model interpretability; bias analysis
Plazo Cumplimiento	EU AI Act effective 2025/2026; baseline testing Q2 2026
Organismo Supervisión	AEPD (AI governance); CNCS (security assessment)
Puntuación Mínima Compliance	85% accuracy under adversarial (Nivel 3); 94%+ (Nivel 5)
Requerimiento Documentación	Adversarial test reports; model cards; risk assessments (per EU AI Act Annex VIII)

SECCIÓN 2: INDICADOR 2 - VULNERABILITY MANAGEMENT IA

Pregunta GQM 2.1: Scanning Coverage IA-Specific

Aspecto	Detalle
Pregunta	¿% sistemas scaneados vulnerabilidades IA-specific (prompt injection, model extraction, data poisoning)?
Métrica	M2.1: AI-Vulnerability Scanning Coverage %
Normativa 1: NIS2	Artículo 19: "Essential entities must conduct regular vulnerability assessments; documented remediation required"
Normativa 2: ISO 27001:2022	A.12.6.1: "Management of technical vulnerabilities: regular assessments, patch management, configuration reviews"
Normativa 3: Plan Nacional	Línea 3.4: "Vulnerability scanning: SBOM validation required for all external components (2026)"
Normativa 4: EU AI Act	Artículo 29: "Providers of AI systems must maintain documentation of known vulnerabilities; update practices"
Normativa 5: OWASP Top 10 for LLM	LLM01: "Prompt Injection" - scanning required
Requisito Técnico	SBOM generation; dependency scanning; model artifact verification; AI-specific CVSS scoring
Plazo Cumplimiento	Implementar Q2 2026 (NIS2 August 2026 deadline)
Organismo Supervisión	CNCS; INCIBE; Entity's external auditor
Puntuación Mínima Compliance	60% systems (Nivel 2); 85% (Nivel 3); 100% (Nivel 5)
Requerimiento Documentación	Vulnerability registers; SBOM; remediation tracking

Pregunta GQM 2.2: MTTR IA-Vulnerabilities (Días)

Aspecto	Detalle
Pregunta	¿Mean Time to Remediate (MTTR) para vulnerabilidades IA vs tradicionales?
Métrica	M2.2: MTTR IA-Vulnerabilities (días)
Normativa 1: NIS2	Artículo 17: "Remediation of identified vulnerabilities according to severity; SLA timelines required"
Normativa 2: ISO 27001:2022	A.12.6.2: "Patch management: critical patches within 15 days; important within 30 days"
Normativa 3: Plan Nacional	Benchmark 2026: "Critical: <15 days; Important: <30 days; Low: <90 days"
Normativa 4: PCI-DSS (if applicable)	Requirement 6.2: "Critical: 30 days max; Important: 90 days"
Requisito Técnico	Automated patch orchestration; configuration management; testing automation; rollback procedures
Plazo Cumplimiento	Baseline Q1 2026; optimization through 2026-2027
Organismo Supervisión	CNCS assessments; Internal audit; External audit per NIS2
Puntuación Mínima Compliance	Critical <30 days (Nivel 2); Critical <15 days (Nivel 3); Critical <5 days (Nivel 5)
Auditoría Tracking	Ticketing system records; patch deployment logs; change management records

Pregunta GQM 2.3: SLA Compliance %

Aspecto	Detalle
Pregunta	¿% vulnerabilidades remediadas dentro SLA por severidad?
Métrica	M2.3: SLA Compliance IA-Vulnerabilities %
Normativa 1: NIS2	Artículo 17: "Operator shall maintain records of all vulnerabilities and remediation efforts; compliance auditable"
Normativa 2: ISO 27001:2022	A.16.1.1: "Incident management: process shall include tracking and trending of vulnerabilities"
Normativa 3: COBIT 2019	BAI07: "Business Process Enablement: control over delivery of IT services includes SLA tracking"
Requisito Técnico	ServiceNow/Jira tracking; automated SLA enforcement; escalation triggers; dashboard reporting
Plazo Cumplimiento	Baseline Q1 2026; continuous tracking
Organismo Supervisión	CNCS (NIS2 audits); Internal Compliance team
Puntuación Mínima Compliance	70% on-time (Nivel 2); 85% (Nivel 3); 95% (Nivel 5)
Metric Derivation	$(\text{Vulns remediadas on-time} / \text{Total detected}) \times 100$

SECCIÓN 3: INDICADOR 3 - DEEFAKE DETECTION

Pregunta GQM 3.2: Detection Accuracy Real-World %

Aspecto	Detalle
Pregunta	¿Accuracy detección deepfakes en condiciones reales (no laboratorio)?
Métrica	M3.2: Detection Accuracy Real-World %
Normativa 1: EU AI Act	Artículo 52: "AI systems that generate deepfakes must be labeled as synthetic; detection capability must be validated"
Normativa 2: Digital Services Act (DSA)	Artículo 24: "Platforms must take action on synthetic media; accuracy of detection systems auditable"
Normativa 3: GDPR	Artículo 22: "Automated decision-making on deepfakes (if used for authentication) prohibited without safeguards"
Normativa 4: Plan Nacional	Línea 6.1: "Emerging threats: deepfake detection systems must be validated Q4 2026"
Requisito Técnico	Multimodal testing (video, audio, text); real-world dataset validation; adversarial robustness testing
Plazo Cumplimiento	Pilot phase 2026; operational deployment Q4 2026/Q1 2027
Organismo Supervisión	AEPD (digital rights); CNCS (security assessment); Platform regulators (DSA)
Puntuación Mínima Compliance	90% accuracy in controlled conditions (Nivel 3); 94%+ real-world (Nivel 5)
Validación Requerida	Third-party testing report; dataset transparency; model documentation

SECCIÓN 4: INDICADOR 4 - SIEM + THREAT HUNTING IA

Pregunta GQM 4.1: Event Processing Capacity

Aspecto	Detalle
Pregunta	¿Volumen eventos/día procesados por SIEM con correlación ML?
Métrica	M4.1: SIEM Event Processing Capacity (eventos/día)
Normativa 1: NIS2	Artículo 17: "Security monitoring systems must be capable of processing volume sufficient for critical infrastructure"
Normativa 2: ISO 27001:2022	A.16.1.5: "Recording and monitoring: retention and analysis capability must match security needs"
Normativa 3: Plan Nacional	Benchmark: "Essential entities: minimum 10M events/day processing capacity"
Requisito Técnico	SIEM infrastructure (Splunk, QRadar, ELK); ML correlation engines; cloud-scalability for spikes
Plazo Cumplimiento	Baseline Q1 2026; capacity planning through 2026-2027
Organismo Supervisión	CNCS (infrastructure assessment)
Puntuación Mínima Compliance	1M events/day (Nivel 2); 10M (Nivel 3); >100M (Nivel 5)
Capacity Planning	Design for 3× peak load; auto-scaling for cloud deployments

Pregunta GQM 4.4: Proactive vs Reactive Discovery %

Aspecto	Detalle
Pregunta	¿% amenazas detectadas proactivamente (threat hunting) vs reactivamente?
Métrica	M4.4: Proactive Detection % = $(\text{Proactive_detections} / \text{Total_detections}) \times 100$
Normativa 1: NIS2	Artículo 17: "Security operations must include both monitoring and proactive threat hunting"
Normativa 2: NIST Cybersecurity Framework	Detect Function: "Advance threat hunting is recommended for high-risk sectors"
Normativa 3: Plan Nacional	Línea 5.3: "SOC capability: threat hunting program required for essential entities (2026)"
Requisito Técnico	Threat intelligence integration; hypothesis-driven investigations; adversary emulation; TTPs tracking
Plazo Cumplimiento	Pilot Q2 2026; operational Q3 2026
Organismo Supervisión	CNCS (SOC assessments); INCIBE (capability evaluation)
Puntuación Mínima Compliance	30% proactive (Nivel 2); 50% (Nivel 3); 90%+ (Nivel 5)
Team Structure	Dedicated threat hunting resource (0.5-1 FTE minimum per 100M event volume)

SECCIÓN 5: INDICADOR 5 - AWARENESS TRAINING IA

Pregunta GQM 5.1: AI-Phishing Click Rate %

Aspecto	Detalle
Pregunta	¿% empleados clickea phishing emails generadas-IA vs tradicionales?
Métrica	M5.1: AI-Phishing Click Rate % = (Clicks / Total_recipients) × 100
Normativa 1: NIS2	Artículo 17: "Human security practices: training and awareness on emerging threats (including IA-enhanced attacks) required"
Normativa 2: GDPR	Artículo 5 (d): "Staff must demonstrate competence in data protection; security awareness is component"
Normativa 3: ISO 27001:2022	A.7.2: "User security awareness and training: all users must receive awareness training; effectiveness measured"
Normativa 4: Plan Nacional	Línea 8.2: "Security culture: employee click-rate target <5% for AI-phishing by 2026"
Normativa 5: CIS Controls v8	Control 11.3: "Address unauthorized software; conduct phishing simulations quarterly minimum"
Requisito Técnico	Phishing simulation platform (KnowBe4, Proofpoint, Gophish); AI-generated email generation; multi-wave campaigns
Plazo Cumplimiento	Baseline Q1 2026; monthly simulations ongoing
Organismo Supervisión	Internal DPO (GDPR angle); CNCS (benchmarking)
Puntuación Mínima Compliance	<20% click-rate (Nivel 1-2); <10% (Nivel 3); <5% (Nivel 5)
Improvement Trajectory	Monthly tracking; trend analysis; department benchmarking

Pregunta GQM 5.2: Phishing Reporting Rate %

Aspecto	Detalle
Pregunta	¿% phishing reportado (vs clicked) por empleados?
Métrica	$M5.2: \text{Phishing Reporting Rate \%} = (\text{Reported} / \text{Total_phishing_sent}) \times 100$
Normativa 1: NIS2	Artículo 17: "Incident reporting: employees must have clear process to report security concerns"
Normativa 2: ISO 27001:2022	A.16.1.2: "Reporting of information security events and weaknesses: procedure established and communicated"
Normativa 3: Plan Nacional	Línea 8.3: "Security reporting culture: target >70% reporting rate for phishing incidents"
Requisito Técnico	Report-phishing button integration; secure reporting channel; feedback loop (simulations + results shared)
Plazo Cumplimiento	Continuous; baseline Q1 2026
Organismo Supervisión	CISO; Chief Compliance Officer
Puntuación Mínima Compliance	30% reporting (Nivel 2); 50% (Nivel 3); 70%+ (Nivel 5)
Psychological Safety	Non-punitive approach (no firing for clicks; only positive reinforcement for reporting)

SECCIÓN 6: INDICADOR 6 - COMPLIANCE NIS2/EU AI ACT

Pregunta GQM 6.1: NIS2 Assessment Coverage %

Aspecto	Detalle
Pregunta	¿% entidades esenciales completó NIS2 self-assessment formal?
Métrica	M6.1: NIS2 Assessment Coverage % = $(\text{Assessed_entities} / \text{Total_EE}) \times 100$
Normativa 1: NIS2 Directiva (2022/2555/EU)	Artículo 17-19: "Essential Entities must conduct risk assessments; documentation required; deadline August 2026"
Normativa 2: Plan Nacional NIS2	Transposición: "Spanish law transposes NIS2; CNCS oversees assessment process; INCIBE provides guidance"
Normativa 3: ISO 27001:2022	Clause 6.1: "Determine context of organization; understand needs and expectations of interested parties"
Normativa 4: COBIT 2019	Governance: "Risk assessment process must be enterprise-wide; documented and reviewed"
Requisito Técnico	Formal risk assessment methodology (NIST, OCTAVE, or equivalent); documentation; evidence collection
Plazo Cumplimiento	HARD DEADLINE: August 2026 (NIS2 transposed by then)
Organismo Supervisión	CNCS España (primary); Autoridades Competentes autonómicas
Puntuación Mínima Compliance	80% assessment completion by June 2026; 100% by August 2026 (regulatory requirement)
Penalty for Non-Compliance	Up to €50M or 10% turnover (per NIS2 Article 30)

Pregunta QQM 6.3: EU AI Act Gap Analysis %

Aspecto	Detalle
Pregunta	¿% organizaciones ejecutó formal gap analysis vs EU AI Act requirements?
Métrica	M6.3: EU AI Act Gap Coverage % = $(\text{Gap_assessed} / \text{Total_organizations}) \times 100$
Normativa 1: EU AI Act (2024/1689)	Article 85: "Transitional arrangements: compliance required by various dates 2025-2026 depending on AI risk level"
Normativa 2: EU AI Regulation Recital 1	"AI systems used in critical infrastructure and security must comply with Article 37 (documentation, risk management)"
Normativa 3: AEPD Guidance (January 2025)	"Spanish organizations deploying AI systems in security must document compliance with AI Act by Q1 2026"
Requisito Técnico	AI impact assessments; model cards; training data documentation; bias testing; adversarial robustness reports
Plazo Cumplimiento	Q1 2026 (AEPD guidance compliance); full compliance Q4 2026
Organismo Supervisión	AEPD (AI governance); CNCS (security integration); Ministry Digital (transposition oversight)
Puntuación Mínima Compliance	60% gap assessed (Nivel 2); 90% (Nivel 3); 100% (Nivel 5)
Requerimiento Documentación	Gap analysis reports; remediation roadmaps; compliance timelines

SECCIÓN 7: INDICADOR 7 - SUPPLY CHAIN RESILIENCE

Pregunta GQM 7.1: SBOM Coverage %

Aspecto	Detalle
Pregunta	¿% componentes IA tiene Software Bill of Materials (SBOM) documentado?
Métrica	$M7.1: SBOM\ AI\ Component\ Coverage\ \% = \frac{Components_documented_SBOM}{Total_AI_components} \times 100$
Normativa 1: EU Cyber Resilience Act (2024/1662)	Article 16: "Manufacturers must provide SBOM; conformity assessment required; transitional period until Sept 2026"
Normativa 2: US Executive Order 14028 (Biden)	Section 4e: "SBOM required for federal government IT products; NTIA minimum elements"
Normativa 3: NIS2	Artículo 19: "Supply chain security: essential entities must assess supplier security; SBOM recommended practice"
Normativa 4: Plan Nacional	Línea 7.1: "Supply chain: SBOM requirement for all critical components by Q4 2026"
Requisito Técnico	SBOM generation tools (CYCLONEDX, SPDX format); dependency scanning; vulnerability correlation; vendor tracking
Plazo Cumplimiento	Baseline Q2 2026; operational deployment Q3 2026; full compliance Q4 2026
Organismo Supervisión	CNCS (supply chain assessment); vendors (compliance verification)
Puntuación Mínima Compliance	60% documentation (Nivel 2); 85% (Nivel 3); 100% (Nivel 5)
Vendor Requirements	All external suppliers must provide SBOM or lose contract eligibility

SECCIÓN 8: INDICADOR 8 - INCIDENT RESPONSE IA

Pregunta GQM 8.1: MTTR Automatizado (Minutos)

Aspecto	Detalle
Pregunta	¿Mean Time to Respond (MTTR) para respuestas iniciales automatizadas?
Métrica	M8.1: MTTR Automatizado (minutos) = $\Sigma(\text{Response_time}) / n_{\text{automated}}$
Normativa 1: NIS2	Artículo 18: "Incident reporting: within 72 hours of discovery to relevant authority; earlier if critical impact"
Normativa 2: GDPR	Artículo 33: "Personal data breach: notify authority without undue delay; 72 hours preferred"
Normativa 3: ISO 27001:2022	A.16.1.1: "Incident management: response procedures must enable timely containment"
Normativa 4: Plan Nacional	Target 2026: "MTTR <30 minutes for critical incidents (automated response)"
Requisito Técnico	SOAR platform (Paloalto Cortex, Splunk SOAR); playbooks automation; escalation routing; integración SIEM
Plazo Cumplimiento	Implementación Q1-Q2 2026; baseline establishment Q2 2026
Organismo Supervisión	CNCS (incident readiness assessments); INCIBE (incident response drills)
Puntuación Mínima Compliance	<2 hours manual response acceptable (Nivel 2); <30 min automated (Nivel 5)
Escalation Criteria	Decision trees for: isolate, shutdown, alert, forensics, external notification

SECCIÓN 9: INDICADOR 9 - GOVERNANCE

Pregunta GQM 9.1: CISO Reporting Level

Aspecto	Detalle
Pregunta	¿A qué nivel jerárquico reporta CISO? (0=none, 1=CTO, 2=COO/CFO, 3=CEO)
Métrica	M9.1: CISO Reporting Level (0-3 score)
Normativa 1: NIS2	Artículo 17: "Governance: essential entities must assign responsibility for cybersecurity at board/executive level"
Normativa 2: ISO 27001:2022	Clause 5.1: "Leadership and commitment: executive leadership must demonstrate commitment; security included in governance"
Normativa 3: COBIT 2019	Governance Framework: "Security governance structure: CISO at executive level minimum (reporting to CEO or equivalent)"
Normativa 4: Plan Nacional	Línea 1.1: "Governance: CISO must have board access; C-level reporting is requirement for critical entities"
Normativa 5: Recomendaciones Internacionales (Gartner, Forrester)	"CISO reporting to CEO: 35% organizations (2025); to CRO: 25%; to CTO: 30% (not best practice)"
Requisito Técnico	Organizational structure formalization; board committee charter; governance documentation
Plazo Cumplimiento	Implementar Q1 2026 (NIS2 expects before August 2026)
Organismo Supervisión	CNCS (NIS2 assessments); Board of Directors
Puntuación Mínima Compliance	Reporting to CEO (score 3) = NIS2 compliant; reporting to CTO (score 1) = non-compliant
Strategic Impact	CISO reporting to CEO correlates with +40% budget allocation (industry data)

Pregunta GQM 9.2: IA-Security Budget Allocation %

Aspecto	Detalle
Pregunta	¿% presupuesto total ciberseguridad dedicado específicamente a IA-security?
Métrica	M9.2: IA-Security Budget % = $(\text{AI_security_budget} / \text{Total_cyber_budget}) \times 100$
Normativa 1: NIS2	Artículo 17: "Essential entities must allocate adequate resources to cybersecurity; budget allocation must reflect risk"
Normativa 2: Plan Nacional	Línea 2.2: "Budget allocation: ≥5% cyber budget to emerging threats (AI, quantum) by 2026"
Normativa 3: COBIT 2019	APO01: "Plan business: budget for enterprise priorities; security is enterprise responsibility"
Requisito Técnico	Budget line items for: SIEM enhancement, AI-threat detection, deepfake systems, training, SOAR, supply chain
Plazo Cumplimiento	Budget 2026 debe incluir IA-security allocation (Q4 2025 budget planning)
Organismo Supervisión	Internal Finance/CFO; Board oversight
Puntuación Mínima Compliance	3% of cyber budget = Nivel 1; 5% = Nivel 2; 8%+ = Nivel 3; 12%+ = Nivel 5
Industry Benchmark (2025)	Average: 6-8% of cyber budget; Forward-thinking: 12%+

SECCIÓN 10: MATRIZ CONSOLIDADA PREGUNTAS → NORMATIVAS

Indicador	Pregunta	Normativa Primaria	Plazo Cumplimiento	Organismo Supervisión	Score Mín. Compliance
AI-Detection	1.1 Coverage %	NIS2 Art.17	Agosto 2026	CNCS	80%
	1.2 MTTD	GDPR Art.33, NIS2 Art.18	Inmediato	AEPD, CNCS	<30 días
	1.3 FP Rate %	ISO 27001 A.16.1.1	Q1 2026	INCIBE	<15%
	1.4 Adversarial Accuracy	EU AI Act Art.15, ISO/IEC 42001	2026	AEPD	85%
Vuln.Mgmt	2.1 Scanning %	NIS2 Art.19, ISO 27001 A.12.6.1	Agosto 2026	CNCS	60%
	2.2 MTTR	NIS2 Art.17, ISO 27001 A.12.6.2	Ongoing	Audit externo	Crítico <15d
	2.3 SLA Compliance	NIS2 Art.17, COBIT 2019	Ongoing	CNCS	70%
Deepfake	3.2 Accuracy Real	EU AI Act Art.52, DSA Art.24	Q4 2026	AEPD	90%
SIEM+Hunting	4.1 Processing Cap	NIS2 Art.17, ISO 27001 A.16.1.5	Q1 2026	CNCS	10M evt/d
	4.4 Proactive %	NIS2 Art.17, NIST CSF	Q3 2026	CNCS	50%
Awareness	5.1 Click Rate %	NIS2 Art.17, ISO 27001 A.7.2	Monthly	CISO	<10%
	5.2 Report Rate %	NIS2 Art.17, ISO 27001 A.16.1.2	Ongoing	DPO	>50%
Compliance	6.1 NIS2 Assess %	NIS2 Art.17, Plan Nacional	AGOSTO 2026	CNCS	100%
	6.3 EU AI Gap %	EU AI Act Art.85, AEPD Guidance	Q1 2026	AEPD	90%
Supply Chain	7.1 SBOM %	EU Cyber Res.Act Art.16, NIS2	Q4 2026	CNCS, Vendors	85%
Incident Response	8.1 MTTR Auto	NIS2 Art.18, GDPR Art.33	Q2 2026	CNCS, INCIBE	<30 min
Governance	9.1 CISO Reporting	NIS2 Art.17, ISO 27001 Cl.5.1	Q1 2026	Board, CNCS	CISO—CEO

	9.2 Budget %	NIS2 Art.17, Plan Nacional	Q4 2025	CFO, Board	5%+
--	--------------	-------------------------------	---------	------------	-----

SECCIÓN 11: REFERENCIAS NORMATIVAS COMPLETAS

Regulaciones Españolas

- Plan Nacional de Ciberseguridad 2023 - CNCS
- Estrategia de Seguridad Nacional Digital - Ministerio Asuntos Exteriores
- Ley de Telecomunicaciones 9/2014 (Marco previo NIS2)

Regulaciones Europeas

- Directiva NIS2 (2022/2555/EU) - Transposición agosto 2026
- EU AI Act (2024/1689) - Aplicación gradual 2025-2026
- GDPR (2016/679) - General Data Protection (ongoing)
- Digital Services Act (2022/2065) - Platform regulation
- EU Cyber Resilience Act (2024/1662) - Supply chain security
- DORA (Digital Operational Resilience Act 2023/2775) - Financial sector

Estándares Internacionales

- ISO 27001:2022 - Information Security Management
- ISO/IEC 42001:2023 - AI Management Systems
- NIST Cybersecurity Framework - US standard (reference)
- NIST AI Risk Management Framework (RMF) - Emerging
- COBIT 2019 - IT Governance

Marcos de Amenaza

- OWASP Top 10 for LLM Applications - AI vulnerabilities
- MITRE ATT&CK Framework - Attack tactics and techniques
- CIS Controls v8 - Critical security controls

FIN DEL MAPEO NORMATIVO